COMPTE-RENDU DE TRAVAUX PRATIQUES

THEME : **INTRODUCTION A LA THREAT INTELLIGENTCE ET RECHERCHE DE VULNERABILITETES**

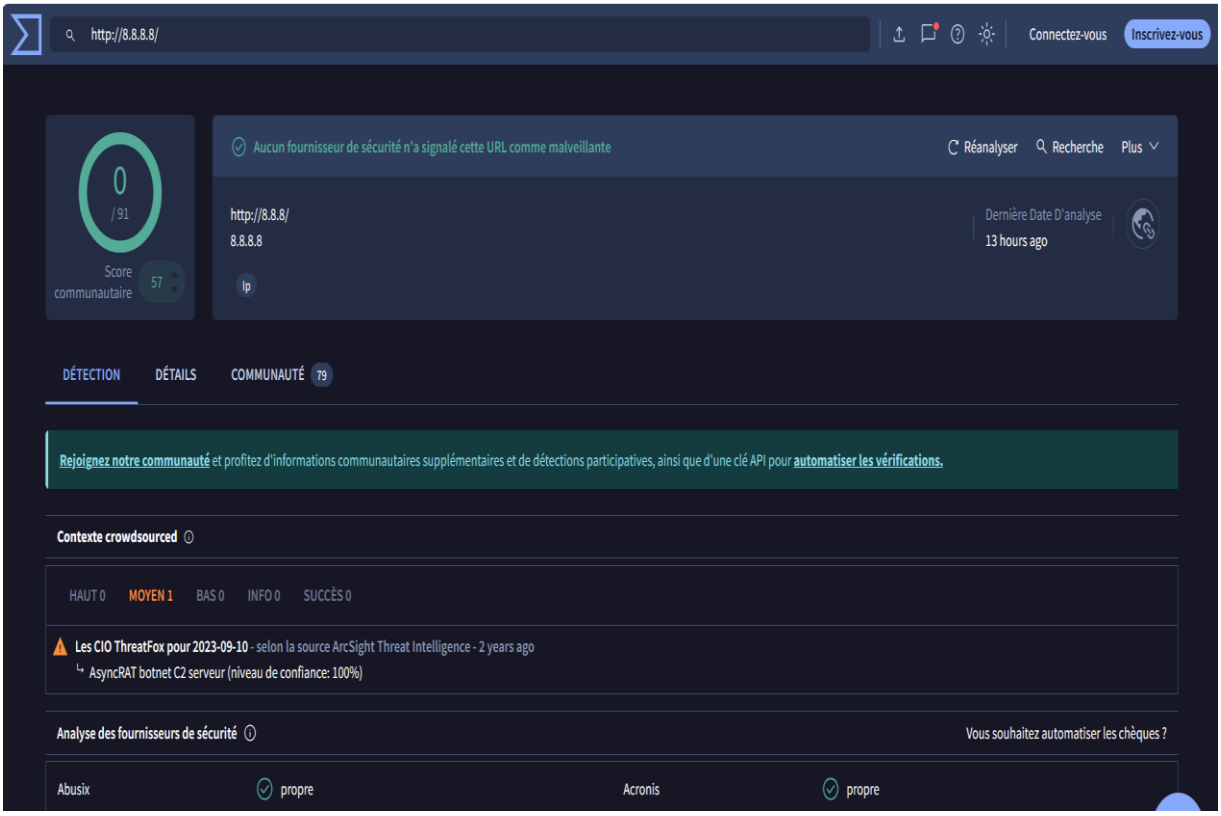
1. INTRODUCTION

la Threat Intelligence : C'est l'ensemble des connaissances basées sur des preuves concernant des menaces existantes ou émergentes. Elle permet d'anticiper les attaques en analysant les tactiques et les vulnérabilités connues.

Rôle dans la cybersécurité : Elle permet de passer d'une défense réactive à une défense proactive en utilisant des bases de données mondiales pour protéger les infrastructures locales.

2. Analyse de l'adresse IP (Analyse de réputation)

Utilisation du site VirusTotal pour analyser l'IP publique 8.8.8.8.



Résultats obtenus : L'analyse montre un score de réputation propre (Clean). Elle est identifiée comme appartenant à Google (DNS public). Cette IP n'est pas signalée comme malveillante. Elle est considérée comme légitime. Pour un analyste SOC, cela permet de décider de ne pas bloquer cette communication.

3. Analyse des services (Couplage Nmap et Searchsploit)

Le scan sur la cible 192.168.56.10 a révélé le service Microsoft-ds.

```
┌──(root㉿kali)-[/home/laurene]
└─# nmap -sV 192.168.56.10
Starting Nmap 7.99 ( https://nmap.org ) at 2026-04-16 15:18 +0200
Nmap scan report for 192.168.56.10
Host is up (0.00056s latency).
Not shown: 998 closed tcp ports (reset)
PORT   STATE SERVICE VERSION
22/tcp open  ssh     OpenSSH 9.6p1 Ubuntu 3ubuntu13.15 (Ubuntu Linux; protocol 2.0)
80/tcp open  http    Apache httpd 2.4.58 ((Ubuntu))
MAC Address: 00:0C:29:B9:97:B5 (VMware)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 11.33 seconds
```

Utilisation de la commande searchsploit apache. L'outil affiche une liste d'exploits disponibles, notamment pour les vulnérabilités de type "Remote Code Execution".

```
Apache Tomcat 3.2.3/3.2.4 - Example Files Web Root Full Path Disclosure                    | multiple/remote/21491.txt
Apache Tomcat 3.x - Null Byte Directory / File Disclosure                                  | linux/remote/22205.txt
Apache Tomcat 3/4 - 'DefaultServlet' File Disclosure                                       | unix/remote/21853.txt
Apache Tomcat 3/4 - JSP Engine Denial of Service                                           | linux/dos/21534.jsp
Apache Tomcat 4.0.3 - Denial of Service 'Device Name' / Cross-Site Scripting               | windows/webapps/21605.txt
Apache Tomcat 4.0.3 - Requests Containing MS-DOS Device Names Information Disclosure       | multiple/remote/31551.txt
Apache Tomcat 4.0.3 - Servlet Mapping Cross-Site Scripting                                 | linux/remote/21604.txt
Apache Tomcat 4.0.x - Non-HTTP Request Denial of Service                                   | linux/dos/23245.pl
Apache Tomcat 4.0/4.1 - Servlet Full Path Disclosure                                       | unix/remote/21412.txt
Apache Tomcat 4.1 - JSP Request Cross-Site Scripting                                       | unix/remote/21734.txt
Apache Tomcat 5 - Information Disclosure                                                   | multiple/remote/28254.txt
Apache Tomcat 5.5.0 < 5.5.29 / 6.0.0 < 6.0.26 - Information Disclosure                     | multiple/remote/12343.txt
Apache Tomcat 5.5.15 - cal2.jsp Cross-Site Scripting                                       | jsp/webapps/30563.txt
Apache Tomcat 5.5.25 - Cross-Site Request Forgery                                          | multiple/webapps/29435.txt
Apache Tomcat 5.x/6.0.x - Directory Traversal                                              | linux/remote/29739.txt
Apache Tomcat 6.0.10 - Documentation Sample Application Multiple Cross-Site Scripting Vulnerabilities | multiple/remote/30052.txt
Apache Tomcat 6.0.13 - Host Manager Servlet Cross-Site Scripting                           | multiple/remote/30495.html
Apache Tomcat 6.0.13 - Insecure Cookie Handling Quote Delimiter Session ID Disclosure       | multiple/remote/30496.txt
Apache Tomcat 6.0.13 - JSP Example Web Applications Cross-Site Scripting                   | jsp/webapps/30189.txt
Apache Tomcat 6.0.15 - Cookie Quote Handling Remote Information Disclosure                 | multiple/remote/31130.txt
Apache Tomcat 6.0.16 - 'HttpServletResponse.sendError()' Cross-Site Scripting              | multiple/remote/32138.txt
Apache Tomcat 6.0.16 - 'RequestDispatcher' Information Disclosure                          | multiple/remote/32137.txt
Apache Tomcat 6.0.18 - Form Authentication Existing/Non-Existing 'Username' Enumeration    | multiple/remote/33023.txt
Apache Tomcat 6/7/8/9 - Information Disclosure                                             | multiple/remote/41783.txt
Apache Tomcat 7.0.4 - 'sort' / 'orderBy' Cross-Site Scripting                              | linux/remote/35011.txt
Apache Tomcat 8/7/6 (Debian-Based Distros) - Local Privilege Escalation                    | linux/local/40450.txt
Apache Tomcat 8/7/6 (RedHat Based Distros) - Local Privilege Escalation                    | linux/local/40488.txt
Apache Tomcat 9.0.0.M1 - Cross-Site Scripting (XSS)                                        | multiple/webapps/50119.txt
```

Identification du service :

Le service ciblé ici est Apache Tomcat. La capture d'écran montre le résultat de la commande searchsploit, qui interroge une base de données d'exploits (Exploit-DB). On y voit une longue

liste de vulnérabilités affectant différentes versions d'Apache Tomcat (un serveur d'applications Java).

Explication d'une vulnérabilité type

Parmi les nombreuses vulnérabilités listées, on peut en expliquer une particulièrement critique présente dans la liste : Remote Code Execution (RCE) (Exécution de code à distance).

• **Le mécanisme** : Dans certaines versions d'Apache Tomcat (comme les versions 7, 8 ou 9 mentionnées en bas de la liste), des failles dans la gestion des requêtes HTTP (souvent liées à l'envoi de fichiers JSP ou à des erreurs de configuration du servlet "default") permettent à un attaquant d'envoyer un fichier malveillant sur le serveur.

• **L'exploitation** : L'attaquant téléverse un "Web Shell" (un petit script). Une fois que le serveur exécute ce script, l'attaquant obtient un accès direct au système d'exploitation.

• **La conséquence :** Cela permet à l'attaquant de prendre le contrôle total du serveur, de voler des données, ou de l'utiliser comme rebond pour attaquer d'autres machines sur le réseau.

Note sur l'origine de l'image

D'après l'analyse technique, cette image n'a pas été créée par une intelligence artificielle de Google. Il s'agit d'une photo prise avec un appareil mobile d'un écran d'ordinateur portable Dell, comme l'indiquent les reflets sur la dalle, la texture des pixels visible en zoomant et la présence du cadre physique de l'ordinateur.

4. Étude d'une CVE (Common Vulnerabilities and Exposures)

La CVE (Common Vulnerabilities and Exposures) choisie pour cette étude est la CVE-2017-0144 .Elle concerne le service SMBv1sur les systèmes Windows. Il s'agit d'une vulnérabilité de type exécution de code à distance (RCE) qui permet à un attaquant non authentifié d'envoyer des paquets spécialement conçus au serveur cible.

Impact : L’impact d'une exploitation réussie de cette CVE est critique pour l'infrastructure :

- Confidentialité : L'attaquant peut accéder à des données sensibles stockées sur la machine.
- Intégrité : Possibilité de modifier, supprimer des fichiers système ou d'installer des logiciels malveillants (backdoors).
- Disponibilité : Risque de provoquer un plantage du système (Denial of Service).

Niveau de gravité

Selon le système de notation CVSS (Common Vulnerability Scoring System), cette vulnérabilité présente un score de :

- Score : [ex: 9.3 / 10]
- Niveau : Critique (ou Élevé selon le score).

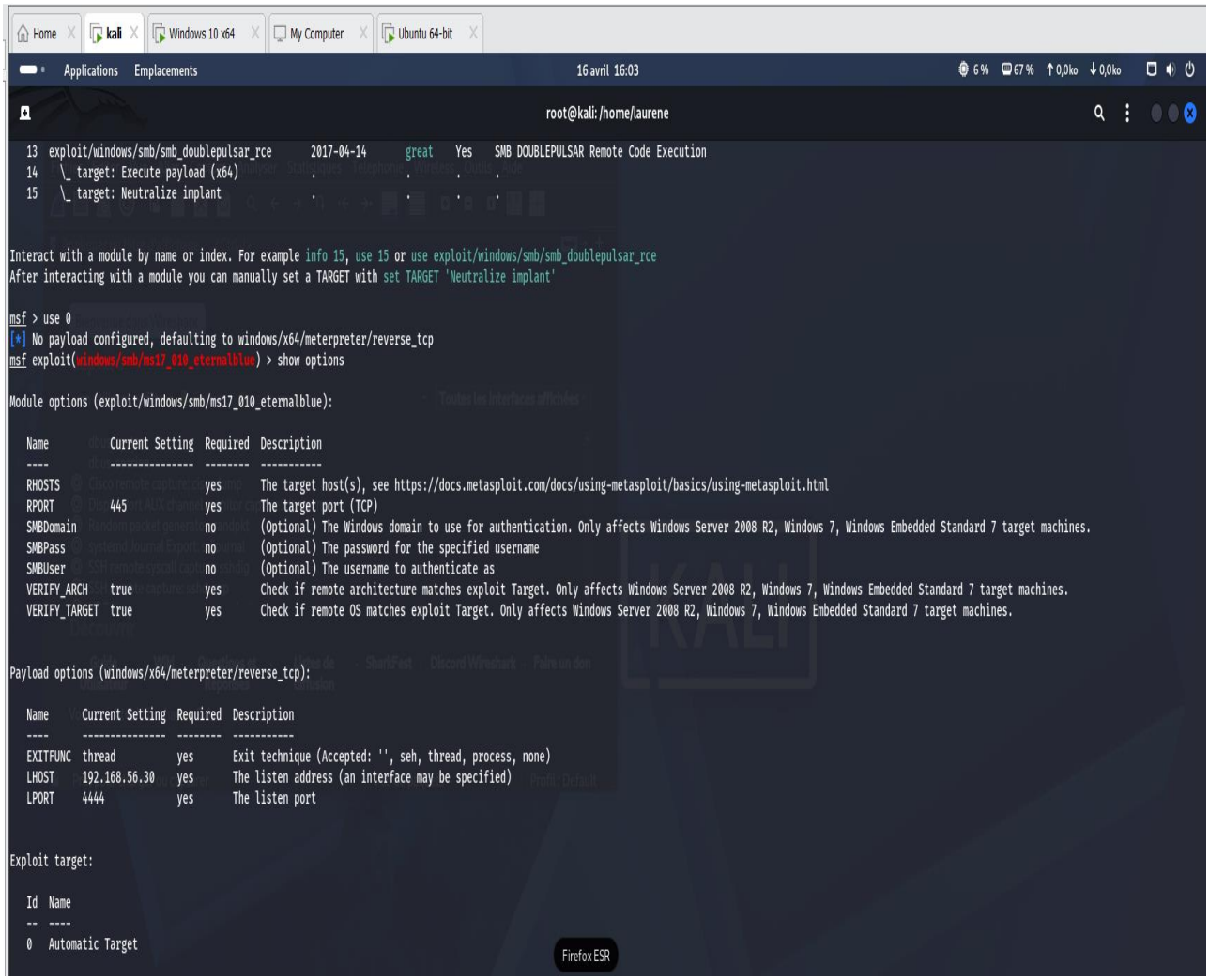
La vulnérabilité est exploitable à distance sans interaction de l'utilisateur et ne nécessite aucun privilège particulier.

Exploitation possible

Un attaquant peut utiliser des outils comme Metasploit ou des scripts personnalisés pour exploiter cette faille.

Scénario : L'attaquant cible le port [ex: 445], injecte une charge utile (payload) et obtient un accès direct au terminal (Shell) avec les droits d'administrateur (ROOT/SYSTEM).

Conséquence finale : Prise de contrôle totale de la machine cible.



5. Utilisation avancée de Searchsploit (Recherche personnelle)

Voici trois options avancées pour optimiser l'utilisation de l'outil :

. Analyse globale de sécurité (Réponses aux questions)

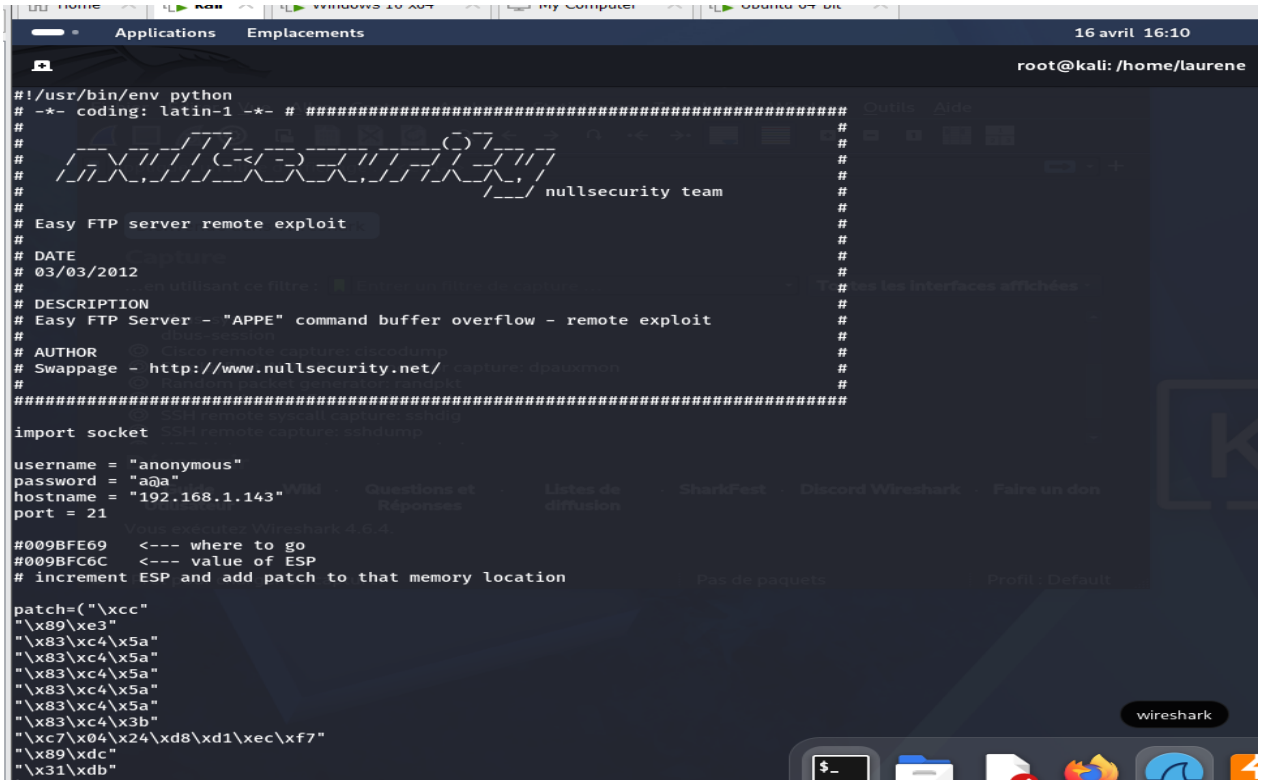
- Quels sont les risques identifiés ?: L'exposition de services obsolètes permet à un attaquant d'utiliser des exploits publics pour prendre le contrôle du serveur.
- Quel service est le plus dangereux ?: Dans mon analyse, le service SMB (Port 445) est le plus critique car il permet souvent un accès profond au système de fichiers Windows.

Quelles actions recommanderiez-vous ?

- Appliquer les correctifs (patchs) de sécurité immédiatement.
- Fermer les ports non nécessaires sur le pare-feu.
- Mettre en place une veille de sécurité (OSINT).

Option Rôle technique Exemple d'usage

-x Examine le contenu d'un exploit directement. searchsploit -x 40234.py (lire le code de l'exploit).



-m Copie l'exploit dans le répertoire actuel. searchsploit –m 42315.py (préparer l'attaque).

```
┌──(root㉿kali)-[/home/laurene]
└─# searchsploit  -m 42315
  Exploit: Microsoft Windows 7/8.1/2008 R2/2012 R2/2016 R2 - 'EternalBlue' SMB Remote Code Execution (MS17-010)
      URL: https://www.exploit-db.com/exploits/42315
     Path: /usr/share/exploitdb/exploits/windows/remote/42315.py
    Codes: CVE-2017-0144
 Verified: True
File Type: Python script, ASCII text executable
Copied to: /home/laurene/42315.py
```

-u Met à jour la base de données des vulnérabilités. searchsploit -u .

```
Applications   Emplacements                                   16 avril 16:16
root@kali: /home/laurene

┌──(root㉿kali)-[/home/laurene]
└─# searchsploit  -u
[i] Updating via apt package management (Expect weekly-ish updates): exploitdb

Error: Could not get lock /var/lib/apt/lists/lock. It is held by process 72972 (apt)
Notice: Be aware that removing the lock file is not a solution and may break your system.
Error: Unable to lock directory /var/lib/apt/lists/

[-] Issue with apt update (Please check network connectivity & apt SourcesList values)
exploitdb is already the newest version (20260411-0kali1).
exploitdb set to manually installed.
The following packages were automatically installed and are no longer required:
  libboost-chrono1.88.0      libboost-program-options1.88.0  libicu76        libipc-run-perl  libsimdutf31  openjdk-21-jre           postgresql-common-dev
  libboost-filesystem1.88.0  libboost-thread1.88.0           libio-pty-perl  libiptcdata0     libteamdctl0  openjdk-21-jre-headless  python3-pysnmp4
Use 'sudo apt autoremove' to remove them.
```

6. Analyse globale de sécurité (Réponses aux questions)

Quels sont les risques identifiés ? L'exposition de services obsolètes permet à un attaquant d'utiliser des exploits publics pour prendre le contrôle du serveur.

Quel service est le plus dangereux ? Dans mon analyse, le service SMB (Port 445) est le plus critique car il permet souvent un accès profond au système de fichiers Windows.

Quelles actions recommanderiez-vous ?

- Appliquer les correctifs (patchs) de sécurité immédiatement.
- Fermer les ports non nécessaires sur le pare-feu.
- Mettre en place une veille de sécurité (OSINT).

7. Lien avec l'entreprise

Comment un SOC utilise la Threat Intelligence ? Les analystes comparent les logs du réseau avec des bases comme VirusTotal ou le MITRE ATT&CK pour identifier si une IP qui les contacte appartient à un groupe de hackers connu.

Comment anticiper une attaque ? En surveillant les nouvelles CVE publiées, l'entreprise peut corriger une faille avant que les pirates n'aient le temps de développer un exploit.

8. Conclusion

Ce TP m'a appris que l'information est une arme. Savoir qu'un service est ouvert est une chose, mais savoir qu'il existe un exploit public pour ce service change totalement la priorité de défense.

Après ce TP : Je comprends que l'analyse de vulnérabilité est une vision proactive de la sécurité. On ne subit pas l'attaque, on l'anticipe en fermant les brèches connues.